

ANTKART PLATFORM

Pre-Flight Inspection Report

End-to-End Testing Configuration — Services Locally, Connected to Real Azure

DATE

June 2026

ENVIRONMENT

Dev (local + Azure)

IDENTITY PROVIDER

Microsoft Entra ID

TENANT ID

4cacc56a-0d38-46c4-ba20-429d51d7b449

KEY VAULT

kv-antkart-dev

SERVICE BUS

sb-antkart-dev

Blocker Summary

Status	Blocker	Scope
BLOCKS ALL	AzureAd:ClientId and AzureAd:Audience are PLACEHOLDER in all 7 services	Every authenticated endpoint fails
BLOCKS	EntraId:* fields are PLACEHOLDER in AK.UserIdentity	Register and all admin endpoints fail
BLOCKS	Discount AuthInterceptor reads Keycloak realm_access.roles — not Entra roles claim	All Discount write gRPC calls return PermissionDenied
WARNING	Notification EmailSettings:Username/Password are empty, host is smtp.mailtrap.io	Emails not delivered unless you switch to Mailhog or add Mailtrap credentials
WARNING	AzureWebJobsStorage = UseDevelopmentStorage=true in Functions local.settings.json	Azure Function will not start locally without Azurite running
OK	Razorpay test keys already committed to appsettings.json	No action required
OK	Product seeding is idempotent and auto-runs in Development	No action required

1. Entra App Role Names

Two role strings are checked across the entire codebase. Both must be defined as Entra **app roles** on the AntKart-API app registration with exactly these values:

Value string (exact)	Display name	Who needs it
admin	Admin (any label)	Admin test user
user	User (any label)	All regular test users

How they flow: AuthenticationExtensions.cs reads every roles claim from the Entra access token and maps each to ClaimTypes.Role. The "admin" policy (policy.RequireRole("admin")) checks that mapped claim. The "authenticated" policy only requires a valid JWT — role doesn't matter.

App role settings in Azure Portal: **isEnabled = true, allowedMemberTypes = User**. The user role is assigned automatically on registration by EntraIdService.RegisterAsync() using the EntraId:UserRoleId GUID.

CRITICAL BUG — DISCOUNT SERVICE

The `AK.Discount.Grpc AuthInterceptor` reads `realm_access.roles` — a Keycloak-specific JWT structure. Entra tokens carry roles in a flat `roles` claim, not inside `realm_access`. Every admin call to Discount gRPC write methods (CreateDiscount, UpdateDiscount, DeleteDiscount) will return `PermissionDenied`. Read-only RPCs are unguarded and work fine. Skip all Discount write tests until this interceptor is fixed.

2. Endpoint Authorization Table

AK.Products — localhost:5077

Endpoint	Method	Required Auth
<code>/api/v1/products</code>	GET	None — <code>.AllowAnonymous()</code>
<code>/api/v1/products/categories</code>	GET	None
<code>/api/v1/products/featured</code>	GET	None
<code>/api/v1/products/{id}</code>	GET	None
<code>/api/v1/products/category/{cat}</code>	GET	None
<code>/api/v1/products</code>	POST	admin role required
<code>/api/v1/products/{id}</code>	PUT	admin role required
<code>/api/v1/products/{id}</code>	DELETE	admin role required
<code>/api/v1/products/bulk-insert</code>	POST	admin role required
<code>/api/v1/products/bulk-update</code>	PUT	admin role required

AK.Order — localhost:5080

Endpoint	Method	Required Auth
<code>/api/orders</code>	GET	Valid JWT — admin sees all, user sees own
<code>/api/orders/me</code>	GET	Valid JWT — always current user's orders
<code>/api/orders/{id}</code>	GET	Valid JWT; 403 if not owner and not admin
<code>/api/orders</code>	POST	Valid JWT (userId from JWT, not body)
<code>/api/orders/{id}/status</code>	PUT	admin role required
<code>/api/orders/{id}</code>	DELETE	Valid JWT; 403 if not owner and not admin

AK.Payments — localhost:5086

Endpoint	Method	Required Auth
/api/payments/initiate	POST	Valid JWT (userId from JWT)
/api/payments/verify	POST	Valid JWT
/api/payments/me	GET	Valid JWT — current user's payments only
/api/payments/{id}	GET	Valid JWT; 403 if not owner and not admin
/api/payments/order/{orderId}	GET	Valid JWT; 403 if not owner and not admin
/api/payments/cards	GET	Valid JWT — current user's cards only
/api/payments/cards/save	POST	Valid JWT (userId from JWT)
/api/payments/cards/{id}	DELETE	Valid JWT — ownership verified in handler

AK.ShoppingCart — localhost:5079

Endpoint	Method	Required Auth
/api/v1/cart	GET	Valid JWT
/api/v1/cart/items	POST	Valid JWT
/api/v1/cart/items/{productId}	DELETE	Valid JWT
/api/v1/cart/items/{productId}	PUT	Valid JWT
/api/v1/cart	DELETE	Valid JWT

AK.Notification — localhost:5087

Endpoint	Method	Required Auth
/api/notifications	GET	Valid JWT — current user's only
/api/notifications/{id}	GET	Valid JWT; 403 if not owner; admin bypasses
/api/notifications/admin	GET	admin role required

AK.UserIdentity — localhost:5085

Endpoint	Method	Required Auth
/api/auth/login	POST	None
/api/auth/register	POST	None
/api/auth/refresh	POST	None
/api/auth/me	GET	Valid JWT
/api/admin/users	GET	admin role required
/api/admin/users/{id}/roles	POST	admin role required

AK.Discount — localhost:5001 (gRPC)

RPC	Required Auth
GetDiscount , GetAllDiscounts , GetDiscountByProductId	None
CreateDiscount , UpdateDiscount , DeleteDiscount	admin — currently broken (reads Keycloak claims)

3. Product Seeding

Seeding is triggered in `Program.cs`:

```
var seedEnabled = app.Environment.IsDevelopment() ||
    string.Equals(app.Configuration["SEED_DATABASE"], "true", ...);
if (seedEnabled) await app.SeedDatabaseAsync();
```

Environment	Seeds?	How
Local dev (<code>ASPNETCORE_ENVIRONMENT=Development</code>)	Yes, automatic on startup	IsDevelopment() is true
Docker Compose	Yes	<code>SEED_DATABASE: "true"</code> is set in docker-compose.yml
Azure (Production)	No	Intentional — do not seed prod data

Idempotency: `ProductSeeder.SeedAsync()` counts documents first. If `count ≥ 300` it returns immediately. Safe to restart. However 1–299 documents triggers a wipe-and-reseed (`DeleteManyAsync` then `InsertManyAsync`).

Target: Cosmos DB (MongoDB API) — database `antkart-products`, collection `products` — via connection string fetched from Key Vault at startup. Cosmos fetch happens before seeding begins.

Verify after start: `GET /api/v1/products/categories` (no auth needed) should return `["Men", "Women", "Kids"]`. Then `GET /api/v1/products?pageSize=1` — `totalCount: 300` confirms the seed completed. If the service crashed at startup, the Key Vault / Cosmos connection is the issue.

4. Razorpay Configuration

Config key	Dev value (already in appsettings.json)	Source
<code>Razorpay:KeyId</code>	<code>rzp_test_SfDi8y9YJGd7DF</code>	appsettings.json directly
<code>Razorpay:KeySecret</code>	<code>iJiuTafS42VfKLES4g0vPjLV</code>	appsettings.json directly

Dev test keys are already committed to `AK.Payments/AK.Payments.API/appsettings.json`. No manual action needed for local testing. `appsettings.Production.json` has empty strings — override for prod with env vars `Razorpay__KeyId` and `Razorpay__KeySecret`.

Test mode: There is no test-mode flag in the code. Razorpay determines test vs. live from the key prefix — `rzp_test_` = sandbox. The committed keys are sandbox keys.

Test cards:

Card	Number	OTP
Visa	<code>4111 1111 1111 1111</code>	<code>1234 1234</code>
Mastercard	<code>5267 3169 4984 2643</code>	<code>1234 1234</code>

5. Notification Email Configuration

AK.Notification.API (MassTransit consumers — long-running process)

Config section: `EmailSettings` in `appsettings.json`

Key	Current dev value	Status
EmailSettings:From	noreply@antkart.com	OK
EmailSettings:DisplayName	AntKart	OK
EmailSettings:Host	smtp.mailtrap.io	Needs credentials
EmailSettings:Port	587	OK (STARTTLS)
EmailSettings:EnableSsl	true	OK
EmailSettings:Username	"" (empty)	Missing
EmailSettings:Password	"" (empty)	Missing

Auth is skipped when Username is empty (`EmailNotificationChannel` guard: `if (!IsNullOrEmpty(Username) && !IsNullOrEmpty>Password))`). With empty credentials, an unauthenticated connection to `smtp.mailtrap.io:587` will be rejected.

Fix options (choose one):

Option	What to set
A — Mailhog (easiest for local dev)	<code>EmailSettings__Host=localhost</code> , <code>EmailSettings__Port=1025</code> , <code>EmailSettings__EnableSsl=false</code> . Run Mailhog: <code>docker run -p 1025:1025 -p 8025:8025 mailhog/mailhog</code> . View emails at <code>http://localhost:8025</code>
B — Mailtrap	Set <code>EmailSettings__Username</code> and <code>EmailSettings__Password</code> from your Mailtrap inbox SMTP credentials
C — Gmail (prod-like)	Use <code>docker-compose.gmail.yml</code> override (gitignored). Host: <code>smtp.gmail.com</code> , Port: <code>587</code> , use a Gmail App Password (not account password)

Recipient address: Comes from the integration event's `CustomerEmail` field — set from `http.GetUserEmail()` when the order is created. It is the email address on the user's Entra ID profile.

AK.Notification.Functions (Azure Function — local)

Reads from `local.settings.json` (gitignored — must exist locally). Template already in repo:

```
{
  "IsEncrypted": false,
  "Values": {
    "AzureWebJobsStorage": "UseDevelopmentStorage=true",
    "FUNCTIONS_WORKER_RUNTIME": "dotnet-isolated",
    "ServiceBusConnection__fullyQualifiedNamespace": "sb-antkart-dev.servicebus.windows.net",
    "ConnectionStrings__Postgres": "Host=localhost;Port=5432;Database=AKNotificationsDb;Username=postgres;Password=postgres"
  },
  "EmailSettings": {
    "From": "noreply@antkart.com",
    "DisplayName": "AntKart",
    "Host": "localhost",
    "Port": 1025,
    "EnableSsl": false
  }
}
```

Verifying the Function fired (without checking inbox):

- Watch `func start` terminal for: `Order-created notification sent for order ORD-...`
- Or query `GET /api/notifications` with the user's JWT — a persisted notification record means the Function completed.
- Failure log: `Failed to deserialize OrderCreatedIntegrationEvent`

6. Entra App Registration Requirements

AzureAd section — required by all 7 services

Currently all 7 services have PLACEHOLDER values:

```
{
  "AzureAd": {
    "TenantId": "4cacc56a-0d38-46c4-ba20-429d51d7b449", // already correct
    "ClientId": "PLACEHOLDER-update-after-terraform-apply",
    "Audience": "api://PLACEHOLDER-update-after-terraform-apply"
  }
}
```

Key	Value to set	Where to find it
AzureAd:TenantId	4cacc56a-0d38-46c4-ba20-429d51d7b449	Already correct in all services
AzureAd:ClientId	Application (client) ID of AntKart-API	Azure Portal → App registrations → AntKart-API → Overview, or <code>terraform output api_client_id</code>
AzureAd:Audience	<code>api://<ClientId></code>	Constructed from ClientId above; must match the <code>aud</code> claim in the token

Set as env vars to avoid committing values: `AzureAd__ClientId=<value>` and `AzureAd__Audience=api://<value>`

EntraId section — AK.UserIdentity only

Key	Where to get it
EntraId:TenantId	4cacc56a-0d38-46c4-ba20-429d51d7b449 (same as above)
EntraId:ClientId	Same as <code>AzureAd:ClientId</code> (AntKart-API client ID)
EntraId:ClientSecret	App registrations → AntKart-API → Certificates & secrets → New client secret. Inject via <code>dotnet user-secrets set "EntraId:ClientSecret" "<value>"</code> or env var <code>EntraId__ClientSecret</code>
EntraId:TenantDomain	Azure Portal → Entra ID → Overview → Primary domain (format: <code>yourname.onmicrosoft.com</code>)
EntraId:ApiObjectId	Service principal Object ID of AntKart-API: <code>az ad sp show --id <ClientId> --query id -o tsv</code>
EntraId:UserRoleId	GUID of the <code>user</code> app role: <code>az ad app show --id <ClientId> --query "appRoles[?value=='user'].id" -o tsv</code>

Swagger OAuth2 redirect URIs

Swagger in this codebase uses **Bearer token input** (paste token into Authorize dialog), not an OAuth2 implicit/PKCE flow. The `AddSecurityDefinition` is `SecuritySchemeType.Http` with `Scheme = "bearer"` — no redirect URI is required for Swagger to work. If you use Postman's OAuth2 flow, register `https://oauth.pstmn.io/v1/callback`.

7. Ordered Pre-Flight Checklist

Phase 1 — Entra App Registration

- ☐ **1.1** Get the `AntKart-API` app registration Client ID from Azure Portal → App registrations → AntKart-API → Overview

- ☐ **1.2** Verify two app roles exist with **Value** exactly `admin` and `user` (isEnabled: true, allowedMemberTypes: User)
- ☐ **1.3** Get the `user` role GUID: `az ad app show --id <ClientId> --query "appRoles[?value=='user'].id" -o tsv`
- ☐ **1.4** Get the service principal Object ID: `az ad sp show --id <ClientId> --query id -o tsv`
- ☐ **1.5** Get tenant default domain from Azure Portal → Entra ID → Overview (format: `*.onmicrosoft.com`)
- ☐ **1.6** Create a client secret on AntKart-API → Certificates & secrets → New client secret. Copy the value immediately.
- ☐ **1.7** Assign the `admin` role to your admin test user (Portal or `POST /api/admin/users/{id}/roles`)
- ☐ **1.8** Verify your normal test user has the `user` role (assigned automatically on register, or manually)

Phase 2 — Fill PLACEHOLDERS (all 7 services)

- ☐ **2.1** Set `AzureAd__ClientId=<ClientId>` and `AzureAd__Audience=api://<ClientId>` — env vars or edit `appsettings.json` in each service (same value in all 7)
- ☐ **2.2** Set UserIdentity-specific values via user-secrets or env vars:
`EntraId__ClientId` , `EntraId__ClientSecret` , `EntraId__TenantDomain` , `EntraId__ApiObjectId` ,
`EntraId__UserRoleId`

Phase 3 — Infrastructure Connectivity

- ☐ **3.1** `az login` with your dev account (DefaultAzureCredential uses this for Key Vault and Service Bus locally)
- ☐ **3.2** Verify Key Vault access: `az keyvault secret show --vault-name kv-antkart-dev --name cosmos-connection-string` — must return value, not 403
- ☐ **3.3** Verify Service Bus: `az servicebus namespace show --name sb-antkart-dev --resource-group rg-antkart-dev-eastus`
- ☐ **3.4** Start local Postgres for Order, Payments, Notification (or confirm Azure Postgres connection strings)
- ☐ **3.5** Start local Redis for ShoppingCart — `localhost:6379`
- ☐ **3.6** Configure email: start Mailhog (`docker run -p 1025:1025 -p 8025:8025 mailhog/mailhog`) OR set Mailtrap/Gmail credentials

Phase 4 — Start Services and Verify

- ☐ **4.1** Start `AK.Products.API` — watch logs for Cosmos Key Vault fetch and seeding. Verify: `GET /api/v1/products/categories` returns `["Men", "Women", "Kids"]`
- ☐ **4.2** Start `AK.Discount.Grpc` — reads work; skip write operations (known bug)

- ☐ **4.3** Start `AK.UserIdentity.API` — test `POST /api/auth/login` with a real Entra test user; confirm JWT returned
- ☐ **4.4** Decode the JWT at `jwt.io` — verify `roles` claim contains `["user"]` or `["admin"]`, and `aud` matches `api://<ClientId>`
- ☐ **4.5** Start remaining services: ShoppingCart, Order, Payments, Notification

Phase 5 — Normal User Golden Path

- ☐ **5.1** `POST /api/auth/login` → get JWT for normal user
- ☐ **5.2** `GET /api/v1/products` (no auth) → confirm 300 products returned
- ☐ **5.3** `POST /api/v1/cart/items` with JWT → add a product; `GET /api/v1/cart` → confirm state
- ☐ **5.4** `POST /api/orders` → create order (email and name populated from JWT claims)
- ☐ **5.5** `POST /api/payments/initiate` → get Razorpay order ID
- ☐ **5.6** `POST /api/payments/verify` → complete payment with Razorpay test card
- ☐ **5.7** `GET /api/notifications` → confirm order-confirmation notification is persisted in DB

Phase 6 — Admin Paths

- ☐ **6.1** `GET /api/orders` (admin JWT) → confirm all users' orders are visible
- ☐ **6.2** `PUT /api/orders/{id}/status` → update order status (Pending → Confirmed)
- ☐ **6.3** `GET /api/notifications/admin` → all notifications across all users
- ☐ **6.4** `GET /api/admin/users` → all Entra users listed
- ☐ **6.5** **Skip** all Discount write gRPC calls — blocked by the Keycloak interceptor bug

Phase 7 — Notification Function (optional)

- ☐ **7.1** Start Azurite: `docker run -p 10000:10000 -p 10001:10001 -p 10002:10002 mcr.microsoft.com/azure-storage/azurite`
- ☐ **7.2** Ensure `local.settings.json` exists in `AK.Notification/AK.Notification.Functions/`
- ☐ **7.3** `cd AK.Notification/AK.Notification.Functions && func start`
- ☐ **7.4** Place an order via the API; watch `func start` terminal for: `Order-created notification sent for order ORD-...`